

Guía metodológica de la Encuesta sobre Indicadores y Métricas ISO/IEC 27001:2022

1. Propósito y alcance

Esta guía acompaña a la “Encuesta Integral sobre Indicadores y Métricas ISO/IEC 27001:2022” y tiene por objeto proporcionar un marco riguroso para su aplicación en organizaciones de distintos sectores y tamaños, con especial énfasis en España y el contexto europeo (NIS2, GDPR y marcos nacionales). [web:31][web:33]

La encuesta se centra en la medición del desempeño del Sistema de Gestión de la Seguridad de la Información (SGSI), entendiendo indicadores y métricas no como un castigo burocrático, sino como el arte de cuantificar cuánto de lo que creemos hacer realmente ocurre. [web:13]

2. Fundamentos normativos y conceptuales

La encuesta se fundamenta en:

- ISO/IEC 27001:2022, especialmente la cláusula 9.1 sobre “monitorización, medición, análisis y evaluación”, que exige establecer qué medir, cómo medirlo y cómo utilizar los resultados para mejorar el SGSI. [web:1][web:33]
- ISO/IEC 27004, que desarrolla la disciplina de la medición en seguridad de la información, y que sirve como referencia conceptual para distinguir entre métricas, indicadores y sistemas de medición. [web:13]
- Guías de ISACA para la construcción de sistemas de KPIs de seguridad, que proporcionan criterios para seleccionar indicadores relevantes, combinar KPIs, KRIs y KCIs, y orientar el sistema a la toma de decisiones. [web:13][web:34]
- Prácticas recientes (2024–2025) sobre KPIs en entornos ISO 27001 y compliance continuo, donde la automatización, la integración con herramientas GRC y el alineamiento con marcos regulatorios se han convertido en la nueva normalidad. [web:31][web:7]

3. Objetivos específicos de la encuesta

La encuesta persigue:

1. Identificar el grado de implantación de sistemas de indicadores ISO 27001 (KPIs, KRIs, indicadores de madurez y resiliencia).
2. Caracterizar las prácticas de diseño metodológico (uso de criterios SMART, referencias a normas como ISO 27004, guías de ISACA, etc.). [web:13][web:33]
3. Analizar el nivel de alineamiento entre indicadores, objetivos del SGSI y objetivos de negocio.
4. Evaluar la integración con el contexto regulatorio (NIS2, GDPR, requisitos nacionales) y con marcos de reporte como los de INCIBE y ENISA. [web:12][web:16][web:20]
5. Medir el grado de automatización, calidad de datos y madurez en el uso de indicadores para la toma de decisiones.

4. Diseño de la encuesta

La encuesta se estructura en 14 bloques, que cubren:

- Caracterización de la organización.
- Gobernanza y sistema de indicadores.
- Metodologías de diseño.
- Indicadores estratégicos y de madurez.
- Gestión de riesgos.
- Controles técnicos y vulnerabilidades.
- Monitorización, SOC e incidentes.
- Concienciación y comportamiento.
- Continuidad y resiliencia.
- Proveedores y cadena de suministro.
- Entorno regulatorio.
- Automatización y calidad de datos.
- Reporte y uso práctico.
- Visión futura y madurez global.

Cada bloque combina preguntas cerradas (para análisis cuantitativo y comparaciones) con espacios abiertos que permiten recoger matices, ironías y sabidurías acumuladas que no caben en las casillas.
[web:13]

5. Población objetivo y muestreo

La encuesta está dirigida a:

- CISOs y responsables de seguridad de la información.
- Responsables de riesgos y de cumplimiento (compliance).
- Responsables de continuidad de negocio y resiliencia.
- Responsables de TI con funciones de seguridad cuando no exista CISO formal.

En organizaciones grandes, se recomienda que el cuestionario sea coordinado por el CISO, recabando aportaciones de áreas como riesgos, TI, continuidad y recursos humanos. En organizaciones más pequeñas, una única persona puede completar la encuesta, idealmente con visibilidad transversal.

El muestreo dependerá del proyecto: puede enfocarse en un sector (por ejemplo, sanitario español), en un territorio (por ejemplo, una comunidad autónoma) o en un tipo de entidad (operadores NIS2). Lo importante es ser explícito sobre la población objetivo para evitar inferencias heroicas.

6. Forma de aplicación

Se recomienda:

- Utilizar un formato electrónico (por ejemplo, formulario web o herramienta de encuesta) basado fielmente en el contenido Markdown del cuestionario.
- Permitir guardar respuestas parcialmente y retomarlas más tarde, dado que algunas preguntas requieren coordinación interna.
- Estimar un tiempo de dedicación de 30–45 minutos por organización, asumiendo que los datos clave están razonablemente localizables.

Idealmente, debería existir una instancia de apoyo (equipo de proyecto) a la que los encuestados puedan dirigir dudas específicas sobre la interpretación de alguna pregunta.

7. Escalas y codificación para análisis

Las preguntas se han diseñado para facilitar:

- Codificación binaria y categórica (sí/no, niveles de alineamiento, rangos de porcentaje).
- Uso posterior de escalas de madurez (por ejemplo, mapeo a niveles 1–5) y cálculo de índices compuestos como el Índice Global de Madurez (IGM) y métricas económicas como ROI de la seguridad. [web:4][web:13]

Se recomienda construir, a partir de las respuestas, al menos:

- Un índice de madurez de indicadores (de 1 a 5).
- Un índice de alineamiento con ISO 27001/ISO 27004.
- Un índice de integración regulatoria (NIS2, GDPR, marcos nacionales).
- Métricas agregadas de automatización y calidad de datos.

La plantilla de Excel propuesta en este kit describe un modo simple (pero ampliable) de implementar estos cálculos.

8. Consideraciones sobre sesgos y calidad de la respuesta

El diseño ha intentado minimizar:

- El sesgo de deseabilidad social (tendencia a sobredimensionar la madurez) mediante preguntas graduadas que admiten respuestas intermedias.
- La ambigüedad terminológica, recurriendo al vocabulario de ISO 27001/27004 y guías reconocidas. [web:13][web:33]
- La tentación de marcar “lo correcto” en lugar de “lo real” recordando –sutilmente– que la realidad es la que luego se audita.

Aun así, se recomienda:

- Acompañar la encuesta con un mensaje claro de confidencialidad y uso de los datos.
- Animar a basar las respuestas en evidencias (por ejemplo, cuadros de mando existentes, registros de auditoría, informes de incidentes, etc.).
- Revisar respuestas “excesivamente perfectas” en contraste con datos objetivos cuando sea posible.

9. Uso de los resultados

Los resultados de la encuesta pueden utilizarse para:

- Elaborar diagnósticos organizativos (por entidad).
- Construir panoramas sectoriales (por ejemplo, nivel de madurez medio de un sector).
- Alimentar la mejora del SGSI, definiendo planes de acción específicos ligados a debilidades en indicadores.
- Informar políticas públicas y estrategias nacionales/regionales de ciberseguridad, al mostrar dónde están los huecos entre la doctrina (ISO, NIS2, ENISA) y la práctica real en las organizaciones.
[web:16][web:20]

Por supuesto, nada impide utilizar los resultados para ganar discusiones en comités de dirección, siempre que se haga con elegancia.

10. Adaptaciones y extensiones

La encuesta está diseñada para ser un marco común, no un dogma inamovible. Se anima a:

- Añadir bloques específicos (por ejemplo, indicadores de OT/ICS, DORA en entidades financieras, o ciberseguridad industrial).
- Profundizar en secciones concretas (por ejemplo, detalle de indicadores de proveedores, o de resiliencia).
- Conectar la encuesta con marcos de evaluación de capacidades (por ejemplo, CMMI, NIST CSF) mediante mapeos adicionales.

Las adaptaciones deben documentarse para preservar la comparabilidad de los resultados en el tiempo y entre organizaciones.

11. Cierre (semi-serio)

La medición en seguridad es, a la vez, ciencia, artesanía y terapia de grupo. Esta encuesta pretende ser un instrumento para ordenar esa conversación, no para añadir otra capa de burocracia vacía. Si, tras completarla, la organización detecta que le sobran indicadores irrelevantes y le faltan unos pocos buenos, la encuesta habrá cumplido su propósito.